TASK

Host Header Injection and Password Reset Poisoning

Suyash A Gunjal

What is Host Header Injection?

HTTP headers are crucial components of HTTP requests and responses that carry vital information about the data being exchanged between a client and a web server.

Host Header Injection is a security vulnerability that occurs when an attacker manipulates the “Host” header in an HTTP request to deceive a web server or application into processing the request as if it were meant for a different domain. This manipulation can lead to various security issues, including website defacement, data exposure, and privilege escalation. Host Header Injection is particularly critical because it can bypass security measures and give rise to other attacks, such as HTTP request smuggling and cache poisoning, making it a significant concern in web security.

Host Header Injection Work:

If a web application does not properly validate or sanitize the Host header, an attacker can modify it as follows:

```
GET /HTTP/1.1
Host: evil.com
```

If the application blindly trusts this value, it may generate incorrect responses, redirect users to malicious sites, or allow attackers to perform unauthorized actions.

Request

Pretty Raw Hex

```
1 GET / HTTP/1.1
2 Host: testphp.vulnweb.com
3 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:142.0) Gecko/20100101 Firefox/142.0
4 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
5 Accept-Language: en-US,en;q=0.5
6 Accept-Encoding: gzip, deflate, br
7 Connection: keep-alive
8 Upgrade-Insecure-Requests: 1
9 Priority: u=0, i
10
11
```

Send Cancel Follow redirection

Request

Pretty Raw Hex

```
1 GET /canonical.html HTTP/1.1
2 Host: evil.com
3 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:142.0) Gecko/20100101
  Firefox/142.0
4 Accept: */*
5 Accept-Language: en-US,en;q=0.5
6 Accept-Encoding: gzip, deflate, br
7 Cache-Control: no-cache
8 Pragma: no-cache
9 Connection: keep-alive
0
1
```

Response

Pretty Raw Hex Render

```
1 HTTP/1.1 200 OK
2 Server: nginx
3 Content-Length: 90
4 Via: 1.1 google
5 Date: Tue, 09 Sep 2025 19:19:25 GMT
6 Age: 75514
7 Content-Type: text/html
8 Cache-Control: public,must-revalidate,max-age=0,s-maxage=3600
9
10 <meta http-equiv="refresh" content="
  0;url=https://support.mozilla.org/kb/captive-portal"/>
```

To Prevent Host Header Injection:

1. Employ Vulnerability Scanner
2. Enforce a Whitelist for Host Headers
3. Validate and Sanitize Inputs
4. Avoid Using Host Headers for Security Decisions
5. Secure Your Web Server
6. Use a Web Application Firewall (WAF)

Password Reset Poisoning

What is Password Reset Poisoning?

Password reset poisoning is a technique whereby an attacker manipulates a vulnerable website into generating a password reset link pointing to a domain under their control. This behaviour can be leveraged to steal the secret tokens required to reset arbitrary users' passwords and, ultimately, compromise their accounts.

How Password Reset Poisoning Works:

1.User requests password reset - Website asks for email.

2.Server builds reset link using the Host header (e.g., http://evil.com/reset?token=xyz).

3.Attacker changes Host header to their malicious domain when requesting reset.

4.Server sends email to victim with attacker’s malicious reset link.

5.Victim clicks link - goes to attacker’s server, token gets stolen.

6.Attacker uses token on real site - resets victim’s password.

To Prevent Password Reset Poisoning:

1. Don’t trust Host headers -never build reset links from user-supplied values.

2.Hardcode the domain in server/app config for reset links.

3.Whitelist allowed domains reject requests with unexpected hosts.

4.Always use HTTPS for reset links.

5.Use strong, short-lived tokens (expire quickly, single use).

6.Log & monitor suspicious reset requests.

Web Security Academy

Basic password reset poisoning

Back to lab description »

LAB Solved

Congratulations, you solved the lab!

Share your skills! Continue learning »

Home | My account | Log out

My Account

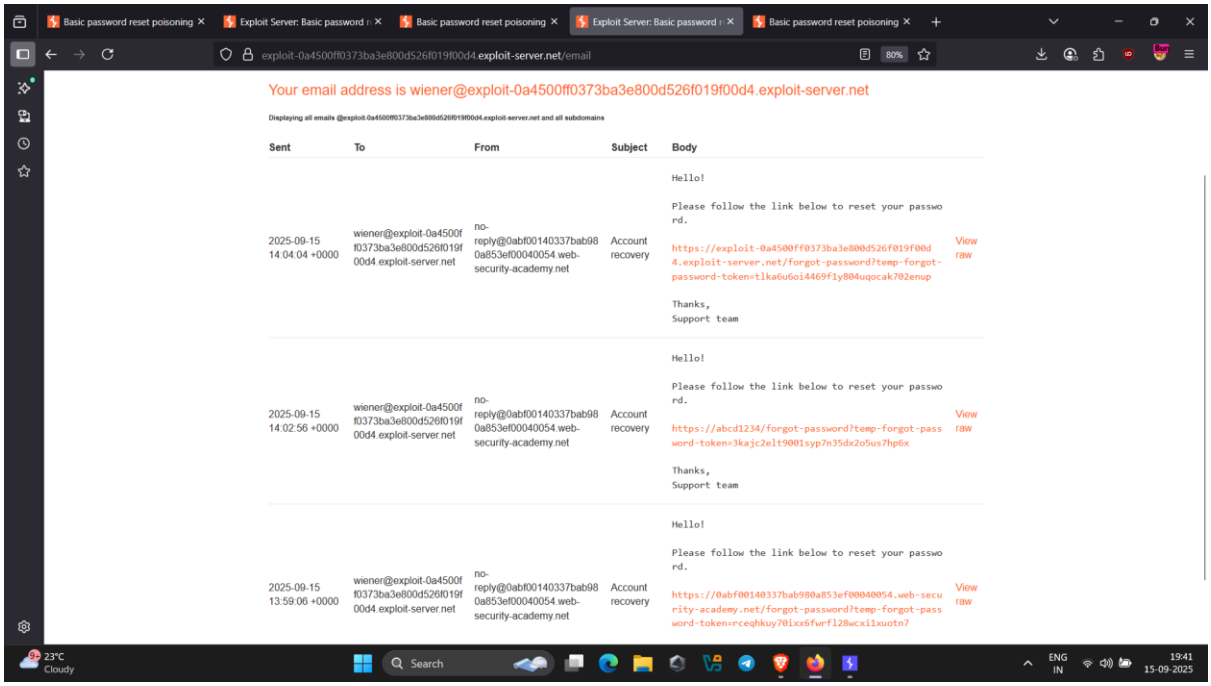
Your username is: carlos

Your email is: carlos@carlos-montoya.net

Email

Update email

```
152.56.4.37     2025-09-15 13:59:10 +0000 "GET / HTTP/1.1" 200 "user-agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:142.0) Gecko/20100101 Firefox/142.0"
152.56.4.37     2025-09-15 13:59:10 +0000 "GET /resources/css/labsDark.css HTTP/1.1" 200 "user-agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:142.0) Gecko/20100101 Firefox/142.0"
152.56.4.37     2025-09-15 13:59:15 +0000 "POST / HTTP/1.1" 302 "user-agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:142.0) Gecko/20100101 Firefox/142.0"
152.56.4.37     2025-09-15 13:59:15 +0000 "GET /email HTTP/1.1" 200 "user-agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:142.0) Gecko/20100101 Firefox/142.0"
152.56.4.37     2025-09-15 13:59:15 +0000 "GET /resources/css/labsDark.css HTTP/1.1" 200 "user-agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:142.0) Gecko/20100101 Firefox/142.0"
152.56.4.37     2025-09-15 13:59:15 +0000 "GET /resources/js/domPurify-2.0.15.js HTTP/1.1" 200 "user-agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:142.0) Gecko/20100101 Firefox/142.0"
152.56.4.37     2025-09-15 13:59:16 +0000 "GET /resources/js/domPurify-2.0.15.js HTTP/1.1" 200 "user-agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:142.0) Gecko/20100101 Firefox/142.0"
152.56.4.37     2025-09-15 13:59:45 +0000 "GET / HTTP/1.1" 200 "user-agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:142.0) Gecko/20100101 Firefox/142.0"
152.56.4.37     2025-09-15 13:59:45 +0000 "GET /resources/css/labsDark.css HTTP/1.1" 200 "user-agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:142.0) Gecko/20100101 Firefox/142.0"
152.56.4.37     2025-09-15 13:59:48 +0000 "POST / HTTP/1.1" 302 "user-agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:142.0) Gecko/20100101 Firefox/142.0"
152.56.4.37     2025-09-15 13:59:48 +0000 "GET /email HTTP/1.1" 200 "user-agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:142.0) Gecko/20100101 Firefox/142.0"
152.56.4.37     2025-09-15 13:59:48 +0000 "GET /resources/css/labsDark.css HTTP/1.1" 200 "user-agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:142.0) Gecko/20100101 Firefox/142.0"
152.56.4.37     2025-09-15 13:59:48 +0000 "GET /resources/js/domPurify-2.0.15.js HTTP/1.1" 200 "user-agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:142.0) Gecko/20100101 Firefox/142.0"
152.56.4.37     2025-09-15 13:59:49 +0000 "GET /resources/js/domPurify-2.0.15.js HTTP/1.1" 200 "user-agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:142.0) Gecko/20100101 Firefox/142.0"
152.56.4.37     2025-09-15 14:03:05 +0000 "GET /email HTTP/1.1" 200 "user-agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:142.0) Gecko/20100101 Firefox/142.0"
152.56.4.37     2025-09-15 14:03:05 +0000 "GET /resources/css/labsDark.css HTTP/1.1" 200 "user-agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:142.0) Gecko/20100101 Firefox/142.0"
152.56.4.37     2025-09-15 14:03:05 +0000 "GET /resources/js/domPurify-2.0.15.js HTTP/1.1" 200 "user-agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:142.0) Gecko/20100101 Firefox/142.0"
152.56.4.37     2025-09-15 14:03:06 +0000 "GET /resources/js/domPurify-2.0.15.js HTTP/1.1" 200 "user-agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:142.0) Gecko/20100101 Firefox/142.0"
152.56.4.37     2025-09-15 14:03:44 +0000 "GET / HTTP/1.1" 200 "user-agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:142.0) Gecko/20100101 Firefox/142.0"
152.56.4.37     2025-09-15 14:03:45 +0000 "GET /resources/css/labsDark.css HTTP/1.1" 200 "user-agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:142.0) Gecko/20100101 Firefox/142.0"
10.0.3.186      2025-09-15 14:04:43 +0000 "GET /forgot-password?temp-forgot-password-token=0x7ck9mqsm7120fducz97f1f6qj2wk08 HTTP/1.1" 404 "user-agent: Mozilla/5.0 (Victim) AppleWebKit/537.36 (KHTML, like Gecko)
152.56.4.37     2025-09-15 14:05:01 +0000 "POST / HTTP/1.1" 302 "user-agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:142.0) Gecko/20100101 Firefox/142.0"
```



References:

https://portswigger.net/web-security/jwt

https://medium.com/swlh/hacking-json-web-tokens-jwts-9122efe91e4a